OpenHarmony-Audit-Agent 工具使用说明书

本说明书介绍环境依赖、安装配置、任务运行、结果读取及演示材料的使用方法。工具以角色化源码审计工作流为主体，CodeQL-AI 按需提供路径与保护条件复核。

1. 功能概述

主体加载目标配置，拆分分析单元，生成 worker 任务包、角色提示词和检查点提示词。运行时支持 Claude Code 与 Codex CLI，执行源码调查并保存事件日志、检查点和任务状态。候选复核通过角色协议组织。

CodeQL-AI 提供经验检索、查询优化、函数读取和符号验证接口。使用这些能力时，需要配置相应依赖和 MCP 服务，并在调用层组织证据转换与归档。原理演示网页用于交互讲解，运行记录回放用于查看实际任务过程。

2. 环境依赖

场景	依赖	配置说明
离线 HTML	Chrome、Edge、Firefox 或 Safari 等现代浏览器	双击 HTML 即可阅读；原理演示可独立离线打开
主体准备与状态读取	Python 3.10+、pip、setuptools ≥ 68	基础 Python 包无第三方运行依赖；使用独立虚拟环境
主体实际审计	Codex CLI 或 Claude Code、可用模型、认证与源码	配置 runtime.adapter、command、model；实际审计会使用模型配额
可选 CodeQL	CodeQL CLI、数据库、查询包及目标构建环境	按所需静态分析任务配置
可选 CodeQL-AI	.[codeql-ai]：FastMCP、angr、pyelftools、tabulate	符号验证需匹配的二进制和调试信息；平台兼容性按依赖要求配置
报告生成	.[pdf]：ReportLab、pypdf、pdfplumber	默认中文字体为 Windows msyh.ttc；其他系统通过字体参数指定
性能采样	.[benchmark]：psutil	统计本机父子进程 RSS；远端模型服务资源另行计量
网页维护与回归	Node.js 22+、npm、Chrome	npm ci 安装 puppeteer-core；浏览器路径按本机配置

已记录的 Parcel 审计环境为 Windows 11、Python 3.14.0、Codex CLI 0.163.0-alpha.10.2 和配置模型 gpt-6-astra。可用模型名取决于所连接服务。认证信息保存在 CLI 认证目录或环境变量中，配置文件仅记录模型、端点和变量名。

3. 安装与运行时配置

在源码根目录执行以下 Windows PowerShell 命令。Linux / macOS 将虚拟环境解释器路径替换为 .venv/bin/python。

```
python --version
python -m venv .venv
.\.venv\Scripts\python.exe -m pip install -e .
.\.venv\Scripts\python.exe -m openharmony_audit --help
```

主体提示词位于 prompts/，示例配置位于 config/。安装后可使用抽象目标完成结构检查；实际任务还需要真实源码及可用模型服务。

Codex CLI 使用 config/workflow.codex.example.json，Claude Code 使用 config/workflow.audit.example.json。将所选示例复制为 config/workflow.local.json，并修改下列字段：

字段	配置内容
runtime.adapter	codex 或 claude-code
runtime.command	codex、claude，或本机可执行文件的绝对路径
runtime.model	服务实际支持的模型名称，替换 replace-with-model
runtime.inheritEnv	需要继承的认证或服务环境变量名称
runtime.mainTimeoutSeconds / maxCycles	单轮运行超时和最大恢复轮数
parallelism.rootWorkers	同时运行的根 worker 数量
promptDir	提示词目录；配置保存在 config/ 时默认 ../prompts

运行前在同一系统用户下完成对应 CLI 的认证，并通过 codex --version 或 claude --version 确认命令可用。Codex runner 保留用户认证目录；Claude Code 使用隔离 worker 目录，可通过 inheritEnv 提供所需凭据。

独立 OpenAI-compatible HTTP 适配器支持 base_url、模型名及 API key 环境变量，供程序直接调用。workflow run 的运行时选项为 Codex CLI 和 Claude Code。

网页维护环境在 frontend/ 目录执行 npm ci 安装依赖，npm run test:demo 检查离线演示交互。原工作台的 npm test 需要启动本地网页服务。

4. 任务准备、运行与恢复

4.1 抽象目标演练

以下命令完成配置检查、分片计划和任务包生成，使用抽象路径，无需模型调用：

```
$py = ".\.venv\Scripts\python.exe"
$wf = "config/workflow.codex.example.json"
$target = "config/target.openharmony.abstract.json"
& $py -m openharmony_audit workflow validate --workflow $wf --target $target
& $py -m openharmony_audit workflow plan --workflow $wf --target $target
& $py -m openharmony_audit workflow prepare --workflow $wf --target $target --run-root reports/abstract-run
--allow-missing-source
& $py -m openharmony_audit workflow status --run-root reports/abstract-run
```

validate 成功输出 VALID。plan 显示分析单元和 worker 分配；prepare 写入任务包；运行前 status 显示 NOT_STARTED。

4.2 实际源码任务

复制 config/target.openharmony.abstract.json 为 config/target.local.json，填写 source.root、source.revision、units 和 threatModel。source.root 指向源码目录，revision 记录已检出的 commit，units.path 使用源码根目录下的相对路径，focus 描述审计关注点。

Parcel 实例使用官方 commonlibrary_c_utils 仓库，版本 b807d3dadb7dbb7639fe85b3a5f72da18d318da2，单元路径为 base/src/parcel.cpp，关注 WriteBuffer、EnsureWritableCapacity 和 WriteDataBytes。任务配置及运行记录保存在 reports/operation-demo/session.json，展示路径已用占位符替换，复现时需填写本机路径。

实际任务使用独立运行目录。修改配置后执行严格检查和任务准备，再启动审计：

```
$wf = "config/workflow.local.json"
$target = "config/target.local.json"
$run = "reports/parcel-run-01"
& $py -m openharmony_audit workflow validate --workflow $wf --target $target --strict-source
& $py -m openharmony_audit workflow plan --workflow $wf --target $target
& $py -m openharmony_audit workflow prepare --workflow $wf --target $target --run-root $run
& $py -m openharmony_audit workflow run --run-root $run
& $py -m openharmony_audit workflow status --run-root $run
```

严格检查核对源目录与单元存在性，源码版本需与本地检出状态一致。已有运行目录用于续作，新任务使用新目录。重复 prepare 会重写计划和提示词，应避开正在执行的任务目录。

4.3 产物与状态

产物	用途
plan.json	目标、运行时、阶段、分析单元与 worker 计划
workers/worker-*/assignment.json	单个 worker 的范围和产物路径
prompt.md、roles.md、blind-verifier.md	总控、角色与独立复核协议
checkpoint-prompt.md、checkpoint.json	检查点整理提示及任务恢复信息
controller-*.stream.jsonl、checkpoint-*.stream.jsonl	运行和检查点事件日志
worker-state.json、run-result.json	worker 状态及运行汇总
shared/candidates、shared/verification、shared/reports	候选、复核与报告目录

Agent 按协议维护状态文件。runner 在允许的轮数内继续未结束任务，已处于终态的 worker 被跳过。中断后检查 checkpoint.json、worker-state.json 和日志，再对原目录执行 workflow run 续作。COMPLETE 表示任务处理完成，漏洞判定记录在候选及复核产物中。

5. 辅助接口与报告生成

CodeQL-AI 的 MCP 服务入口为 src/openharmony_audit/engines/codeql_ai/mcp/server.py。具体工具参数见该模块和 providers.py。将服务接入所选 Agent 环境后，按候选问题调用经验、函数或路径检查；调用结果经复核后关联候选版本。

```
& $py -m pip install -e ".[codeql-ai]"
& $py -m openharmony_audit normalize-sarif --sarif path/to/results.sarif --output reports/findings.json
& $py -m pip install -e ".[pdf]"
& $py -m openharmony_audit report --output reports/technical-report.md --pdf reports/technical-report.pdf
```

SARIF 路径替换为实际文件。normalize-sarif 输出统一 Finding 记录，report 按内置模板生成技术说明书。具体漏洞报告使用候选、证据和复核记录编写。旧 prepare、validate-target 为兼容入口，完整工作流使用 workflow 子命令。

6. HTML 与视频使用

frontend/demo.html 展示八章技术原理与流程。deliverables/03-recording-demo.html 为独立离线版，内嵌样式、交互、环境说明与讲稿，可直接复制到其他电脑打开。

双击 HTML 用浏览器打开。方向键、PageUp / PageDown 翻页，N 显示提示，F 全屏，Escape 关闭提示并暂停播放。第二章演示交接与恢复，第三章展示角色调查，第四章可调整长度和保护条件。

deliverables/03-operation-demo.mp4 为 8 分 34 秒的 Parcel 运行记录回放与原理交互视频。03-operation-replay.html 可独立查看记录；03-operation-voiceover.html 提供时间码讲稿，与 MP4 放在同一目录即可播放视频。

本地服务命令为 python scripts/serve_demo.py，访问 http://127.0.0.1:8765/demo.html；--port 可修改端口，Ctrl+C 停止服务。原理交互使用教学示例，实际记录位于 reports/operation-demo/。

7. 常见问题

现象	处理方式
No module named openharmony_audit	确认安装和运行使用同一虚拟环境，并在源码根目录安装
source root does not exist	核对 source.root；抽象目标准备使用 --allow-missing-source
missing prompt template	保留 prompts 目录，核对 promptDir 与配置文件的相对位置
模型进程启动失败	检查 adapter、command、model、CLI 认证、环境变量和网络
run 很快结束且未产生新审计日志	查看 worker 是否已有终态；新测试使用独立目录
辅助检查缺少数据库或二进制	配置对应 CodeQL 数据库或目标二进制，记录辅助能力可用状态
PDF 字体不存在	build_pdf 支持 font_path；批量生成脚本支持 --font
讲稿页无法播放视频	将 MP4 与讲稿 HTML 放在同一目录，并保留文件名

8. 工程检查与性能复测

在已安装基础包的环境执行测试。性能采样会运行参数中的实际审计命令，测量前配置模型、目标版本和新的任务目录。

```
& $py -m unittest discover -s tests -v
& $py -m pip install -e ".[benchmark]"
& $py scripts/measure_command.py --output reports/perf-run.json --scope source-audit --snapshot YOUR_COMMIT -- $py -m openharmony_audit workflow run --run-root reports/parcel-run-02
```

parcel-run-02 需按第 4 节完成 prepare。测量 JSON 包含墙钟时间、采样进程树 RSS、环境和退出码，命令输出保存至同名 stdout.log。现有实测值及统计口径见工具性能说明。